Departing-Employee Data-Theft Monitoring Quickstart — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Departing-Employee Data-Theft Monitoring Quickstart 5

The problem . . . 5

The solution . . . 5

How it works . . . 5

Why it matters . . . 6

Important boundaries . . . 6

Solution Overview — Departing-Employee Data-Theft Monitoring Quickstart (Microsoft Purview) 6

What this solution delivers . . . 6

This is HR/privacy-sensitive by design — read this first . . . 7

How the pieces fit — the departing-user model . . . 7

The standard deployment model . . . 8

What's in the box . . . 9

Requirements — Departing-Employee Data-Theft Monitoring Quickstart 9

R1. Insider Risk Management licensing (E5 / E5 Compliance / IRM add-on) . . . 9

R2. The Insider Risk Management role groups — configured for STRICT SEPARATION . . . 10

R3. Privacy / anonymization posture agreed and configured . . . 10

R4. Exfiltration indicators turned on globally . . . 10

R5. Endpoint (device) prerequisites for device indicators . . . 11

R6. The Microsoft 365 HR connector (the departing-user trigger) . . . 11

R7. A named pilot scope group . . . 11

R8. (Optional) Priority user group for high-risk leavers . . . 11

R9. HR, legal, privacy (and works-council / employee-relations) engagement and lawful basis . . . 12

R10. Change control for scope expansion . . . 12

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 14

Implementation — Departing-Employee Data-Theft Monitoring Quickstart 14

Named objects (verbatim — used across docs, scripts, tests) . . . 15

Phase 0 — Assess (confirm you can build safely) . . . 15

Phase 1 — Design (agree it with HR/legal, then name everything) . . . 16

Phase 2 — Configure the guardrails FIRST . . . 16
Phase 3 — Wire the trigger (HR connector) . . . 17
Phase 4 — Build the one policy (scoped to the pilot) . . . 17
Phase 5 — Validate (run the gates) . . . 18
Phase 6 — Operate the review flow (and hand off to HR/legal) . . . 18
Phase 7 — Expand (only after the gate passes) . . . 19
Testing & Validation — Departing-Employee Data-Theft Monitoring Quickstart 19
Gate 1 — Role separation is clean (privacy control) . . . 19
Gate 2 — Anonymization is ON . . . 20
Gate 3 — Trigger and indicators are ready . . . 20
Gate 4 — The policy is On and healthy, scoped to the pilot . . . 20
Gate 5 — The trigger actually scopes a leaver . . . 20
Gate 6 — A sanctioned test exfiltration produces a scored alert . . . 20
Gate 7 — Alert triages and escalates into an audited case . . . 21
Gate 8 — HR/legal hand-off confirmed . . . 21
Gate 9 — Reporting rollup is coherent . . . 21
Troubleshooting — Departing-Employee Data-Theft Monitoring Quickstart 21
Insider Risk Management doesn't appear in the portal / Settings won't open . . . 22
The policy is On but produces NO alerts . . . 22
HR connector shows no / stale data — departing-user detection silently stopped . . . 22
Device indicators never fire even though the leaver copied files . . . 23
Reviewers see real names when they shouldn't (or "why is everyone anonymized?") . . . 23
An account can both build the policy and unmask identities (separation broken) . . . 23
"Access denied" triaging alerts or opening a case . . . 23
Alerts are overwhelming / lots of false positives in the pilot . . . 23
A user resigned but was never scored . . . 23
`Get-InsiderRiskPolicy` / IRM cmdlets aren't recognized . . . 24
`IRMDEPART-Report.ps1` returns no records . . . 24
Connect-IPPSSession / Connect-MgGraph fails . . . 24
Best Practices — Departing-Employee Data-Theft Monitoring Quickstart 24
Privacy first — always . . . 25
Role separation — enforce it, then watch it . . . 25
Determinations stay with HR/legal . . . 25
Make the leaver trigger reliable — this is where the value lives . . . 25
Detection hygiene . . . 26
Pilot and tune before you rely . . . 26

Operations and evidence integrity . . . 26
Change control and safety . . . 26
Fit with the rest of Purview . . . 27
Deliverables Summary — Departing-Employee Data-Theft Monitoring Quickstart 27
Documentation . . . 27
PowerShell tools (5) . . . 28
Named objects (verbatim — used across docs, scripts, and tests) . . . 29
What this solution deliberately does NOT do . . . 29
Appendix A — PowerShell Scripts 31

Executive Summary — Departing-Employee Data-Theft Monitoring Quickstart

The problem

The single riskiest moment for your data is when an employee **decides to leave**. Between the resignation and the last day, a departing user — with full, legitimate access — copies files to a USB stick, syncs a folder to personal cloud storage, or emails a customer list to a private address. It rarely looks like an attack, because it isn't one: it is someone who already has the keys, on the way out. Studies consistently find that a large share of insider data loss clusters around departures — and most organizations have **no visibility** into it until the person, and the data, are gone. Addressed clumsily — with blanket employee surveillance — it costs something else: employee trust, and potentially compliance with privacy and labour law.

The solution

This is a **focused quickstart** that delivers the **one** Microsoft Purview capability built for exactly this risk: a **Data theft by departing users** insider-risk policy — configured end to end, **the responsible way**. It detects exit-time exfiltration from signals your Microsoft 365 tenant already produces, and does so **with privacy guardrails and HR/legal in the loop**:

- **Privacy by design.** Usernames are **anonymized (pseudonymized)** for reviewers by default; identity is revealed only when justified, role-permitted, and **audited**. The policy is scoped to the **minimum** population — actual and imminent **leavers**, not the whole company.
- **Strict role separation.** The people who **build the policy** (Admins), **triage and investigate** (Analysts/Investigators), and **audit the reviewers** (Auditors) are deliberately kept separate, using purpose-built role groups — so no one both defines risk and unmasks identity unchecked.
- **Determinations stay with HR/legal.** The policy produces **evidence and an audited case trail**; whether an alert reflects misconduct, and what the consequence is, is an **HR/legal determination** — never a technical default and never the administrator's call.

The result is a governed, defensible monitoring capability: exit-time theft detected, triaged into cases, evidence routed to the right people — **without overreach**.

How it works

We follow a repeatable model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — that configures the **privacy and role-separation guardrails first**, then turns on the exfiltration indicators, wires the **HR connector** (the leaver trigger that keeps the policy narrow), builds the one policy from Microsoft's template, and validates it against a **sanctioned test** in a pilot scope before anyone relies on alerts. Every high-impact change is piloted and reversible.

The solution ships as **self-guided documentation plus five PowerShell tools** (Security & Compliance PowerShell / Graph) that assess role separation and privacy settings, check HR-connector and indicator readiness, validate the policy prerequisites, produce a leadership rollup, and stage scope expansion — all **read-only or preview-by-default**, with **no credentials in code**.

Why it matters

• **Catch theft on the way out** — the highest-probability data-loss moment — instead of finding out after the person and the files are gone.

• **Respect privacy and the law** — anonymization, minimal (leaver-only) scope, and separated duties, engaged with HR/legal/privacy from the start.

• **Defensible evidence, clear ownership** — an audited alert→case trail, with the **determination in the right hands**.

• **A fast, focused win** — one capability, delivered and validated, at a fraction of consulting cost; a foundation you can later grow into a full insider-risk program.

Important boundaries

Insider Risk Management is **licensing-dependent** (Microsoft 365 E5 / E5 Compliance / IRM add-on; some capabilities are additional or in preview) and the Purview portal is **evolving** — capability availability should be **verified against your licensing and tenant**. The policy **monitors people**: in many jurisdictions this requires notice, consultation, or a specific **lawful basis** before it is enabled — that applicability is a **legal determination** for your organization, and this solution provides the technical method and guardrails, not the legal decision. Investigative and disciplinary **outcomes remain with HR/legal**.

Solution Overview — Departing-Employee Data-Theft Monitoring Quickstart (Microsoft Purview)

What this solution delivers

The single riskiest moment for your data is when an employee **decides to leave**. Between the resignation and the last day, a departing user — with full, legitimate access — copies files to a USB stick, syncs a folder to personal OneDrive, or emails a customer list to a private address. It rarely looks like an attack, because it isn't one: it is someone who already has the keys, on the way out the door. Most organizations have **no visibility** into it until the person is gone.

This is a **focused quickstart**: it delivers the **one** Microsoft Purview capability that catches exactly this — a **Data theft by departing users** insider-risk policy — end to end, without the scope of a full insider-risk program. You get the departing-user policy, the **HR connector** that tells Purview who is leaving (the trigger), and the **alert** → **case review flow** that routes evidence to the right people — configured, **piloted in a limited scope** first, validated against pass/fail gates, and operable.

It walks a competent-but-novice administrator through:

1. **Configure the privacy guardrails and role separation FIRST** — anonymization (pseudonymization) of

usernames in the reviewer experience, and the split between who *builds* the policy (Admins), who *triages/investigates* (Analysts/Investigators), and who *audits the reviewers* (Auditors). This is deliberately step one, not an afterthought.

1. **Wire the trigger** — the **Microsoft 365 HR connector** that imports resignation/termination dates

so Purview knows who is a leaver (or, with no HR feed, the **Entra account-deletion** trigger as a coarser fallback).

1. **Build the one policy** — `IRM-DepartingUser-DataTheft` from Microsoft's **Data theft by departing

users** template, scoped to a named pilot group, with the exfiltration indicators it needs.

1. **Operate the review flow** — triage the alert queue, escalate a real signal into a **case**, and

hand any investigative or disciplinary **outcome to HR/legal**. The tooling gives you the technical evidence and an audited trail; **it does not make the employment decision**.

The result: a **blind spot** (no visibility into exit-time data theft) becomes a **governed, defensible, privacy-respecting monitoring capability** — proven in a pilot before it drives real cases.

This is HR/privacy-sensitive by design — read this first

A departing-user policy watches **people's activity**, so it carries employee-privacy, works-council, labour-law, and data-protection obligations that a DLP or retention project does not. Three non-negotiable principles run through every step:

- **Privacy by design.** Insider Risk Management **anonymizes (pseudonymizes) usernames by default** in

the reviewer experience — reviewers see coded identifiers, not names, until there is a justified, role-gated, **audited** reason to reveal identity. Keep anonymization **on** unless HR/legal/privacy have agreed otherwise **in writing**. Scope the policy to the **minimum** population needed — realistically, the pool of actual and imminent leavers, not the whole company.

- **Strict role separation.** The person who **defines** what counts as risky (Admin) must not be the

same person who **decides who did it** (Investigator), and both are watched by an independent **Auditor**. Purview provides purpose-built role groups precisely so these duties can be separated — this solution configures them that way and treats any overlap as a finding.

- **Determinations belong to HR/legal.** The policy produces **signals, alerts, evidence, and an audited

case trail**. Whether an alert reflects misconduct, and what the consequence is, is an** HR/legal/privacy determination** — never a technical default and never the administrator's call. The tooling stops at "here is the evidence, routed to the right reviewers"; the outcome is theirs.

> ***Deploy this with your HR, legal, privacy, and (where applicable) works-council / employee-relations stakeholders — not around them.*** *Several regions require notice, consultation, or a lawful basis before monitoring employee activity. Confirm your obligations before you enable the policy. This solution provides the technical method and the guardrails; the* ***applicability and lawful basis are a legal determination*** *(see* `global-requirements-purview.md` *§5).*

How the pieces fit — the departing-user model

- **The policy template.** Microsoft's **Data theft by departing users** template pre-selects the

detections that matter for a leaver: exfiltration to removable media, to personal cloud, by email to external/personal recipients, and downloads/prints of sensitive content. You build one policy from it: `IRM-DepartingUser-DataTheft`.

• **The trigger (why this template needs a connector).** Unlike a general data-leak policy, the departing-user template does **not** score everyone all the time. A user only comes **into scope for detection** once there is a **triggering event**: a **resignation/termination date** from the **HR connector**, or an **Entra account deletion**. No trigger, no scoring — which is exactly what keeps the policy narrow and privacy-respecting.

• **Indicators** are the individual risky activities the policy watches — SharePoint/OneDrive download, file copied to USB or personal cloud, file printed, email sent to an external/personal recipient. Indicators are a **global** switch (Settings → Policy indicators) that the policy draws from; several **device** indicators require **device onboarding** first.

• **The HR connector** brings in the signal Purview does not natively have — who is leaving and when. It is a **CSV/API data connector** configured in the portal; the upload credential lives in the connector app, **never in a script**.

• **Risk scoring → alerts.** A leaver's scored exfiltration activity that exceeds thresholds raises an **alert** in a queue, with a severity.

• **Alerts → cases → HR/legal.** An analyst **triages** each alert (confirm / dismiss). A confirmed, meaningful alert is escalated into a **case** — the container with the user's scored activity, notes, and case actions. Cases are where **Investigators** work and where the **HR/legal hand-off** happens.

The design principle throughout: **detect the minimum, reveal the minimum, and separate who does what** — visibility with guardrails, not surveillance.

The standard deployment model

Every step follows the same repeatable model, with an explicit **pass/fail gate** between phases:

Assess → Design → Configure → Pilot (simulation/limited scope) → Validate → Expand.

• **Assess** — confirm licensing (E5 / E5 Compliance / IRM add-on), the IRM role groups and their separation, portal access, the exfiltration indicators, the HR-connector feed, and **the HR/legal/ privacy sign-off**.

• **Design** — agree the anonymization posture, the pilot scope, the indicators, and the trigger **with HR/legal**. Name every object.

• **Configure** — set privacy + role separation **first**, turn on the indicators, wire the HR connector, then build the one policy from the template.

• **Pilot** — scope the policy to a named pilot group and validate detection with a **sanctioned test** before you rely on alerts.

• **Validate** — run the pass/fail gates in `05-testing.md`.

• **Expand** — widen scope deliberately (e.g. to the standing leaver population) only after the gate

passes and HR/legal confirm the review flow.

What's in the box

• This overview, a **Requirements** guide, an ordered **Implementation** guide, **Testing** (pass/fail gates), **Troubleshooting**, **Best Practices**, a **Deliverables Summary**, and an **Executive Summary**.

• **Five PowerShell tools** (Security & Compliance PowerShell / Graph): a role-separation + privacy **discovery** assessment, an **HR-connector / indicator readiness** checker, a **policy-from-template plan** helper, an **alert/case rollup** report, and a **scope helper** — all **read-only or** `-WhatIf` **by default**; **no credentials in code**.

> ***Sources:*** *Microsoft Learn — *Insider risk management* (policy templates → *Data theft by departing users*, indicators, triggers, the *Microsoft 365 HR connector*, settings/privacy, roles/permissions, alerts and cases). Insider Risk Management is* ***licensing-dependent*** *(Microsoft 365 E5 / E5 Compliance / Insider Risk Management add-on; some capabilities are additional or in preview) and the Purview portal is* ***evolving*** *—* ***verify capability availability against your licensing/tenant*** *rather than assuming.*

Requirements — Departing-Employee Data-Theft Monitoring Quickstart

Confirm every prerequisite below **before** you configure anything. Category-level prerequisites (tenant, licensing model, least-privilege roles, S&C PowerShell / Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, pilot scope + change control) are in `global-requirements-purview.md` — reference them; they are **not** repeated here. The items below are the ones **specific to a departing-user data-theft policy**, especially its **HR-connector trigger**, its **role separation**, and its **privacy** prerequisites.

Each requirement is written as **Description · Why · Verify · Implement if missing.**

> *This capability is* ***HR/privacy-sensitive****. Several requirements below are* ***organizational, not technical*** *(HR/legal engagement, lawful basis, works-council consultation). Treat those as hard gates: they must be satisfied before you enable the policy, and their determination is* ***not yours to make*** *— see* `global-requirements-purview.md` *§5.*

R1. Insider Risk Management licensing (E5 / E5 Compliance / IRM add-on)

Description: Microsoft 365 **E5**, the **E5 Compliance** add-on, or the standalone **Insider Risk Management** add-on, assigned to the users who will be **in scope** of the departing-user policy. **Why:** IRM is a premium, plan-gated compliance capability; without the right licence the *Data theft by departing users* template, several indicators, and the HR connector are unavailable, and scored users must be licensed. **Verify:** Microsoft 365 admin center → **Billing** → **Licenses**; in the Purview portal, **Insider Risk Management** appears in the left navigation and lets you open **Settings**. Cross-check against the *Microsoft Purview service description* — **verify against your licensing/tenant**, do not assume. **Implement if missing:** Acquire and assign the appropriate SKU/add-on to in-scope users before authoring the policy.

R2. The Insider Risk Management role groups — configured for STRICT SEPARATION

Description: The purpose-built IRM role groups assigned so **duties are separated**, not concentrated in one account:

• **Insider Risk Management Admins** — create/configure the **policy and settings**; **cannot** see alert/case user activity.

• **Insider Risk Management Analysts** — **triage** alerts/cases; see the **anonymized** experience unless de-anonymization is justified and role-permitted.

• **Insider Risk Management Investigators** — full case investigation including **content/forensic detail and de-anonymized identity** where justified.

• **Insider Risk Management Auditors** — view the **IRM audit log** (who reviewed/unmasked what) — the independent watch on the reviewers.

• **Insider Risk Management** (the combined "everything" role group) — **avoid** assigning it to real operators in production; it defeats separation. Use the granular groups. **Why:** Role separation is the core privacy control: the person who **defines** risk must not be the person who **unmasks** identity, and both must be **independently audited**. Concentrating roles is a governance failure and, in many regions, a compliance one. **Verify:** Purview portal → **Settings** → **Roles & scopes** → **Permissions** (or **Roles & scopes**), or run `IRMDEPART-Discovery.ps1` — confirm each role group has the **right, minimal** membership and that **no single person holds a conflicting combination** (e.g. Admin **and** Investigator). **Implement if missing:** Assign the least-privilege IRM role groups under change control, mapping named people to **one** function each. Record the mapping with HR/legal.

R3. Privacy / anonymization posture agreed and configured

Description: A decision — **made with privacy/HR/legal** — on the IRM **global privacy setting**, specifically **anonymization (pseudonymization) of usernames** in the reviewer experience, kept **ON** by default, with de-anonymization treated as a justified, role-gated, audited exception. **Why:** Anonymization is what lets you detect leaver risk **without** exposing employee identity to reviewers by default; turning it off changes the privacy and legal posture of the whole program. **Verify:** Purview portal → **Insider Risk Management** → **Settings** → **Privacy** — confirm **"Show anonymized versions of usernames"** is selected. `IRMDEPART-Discovery.ps1` flags the posture to confirm in-portal (the privacy setting is portal-managed). **Implement if missing:** Set anonymization **on** and document who may de-anonymize, on what basis, with what approval. Do **not** disable anonymization without written privacy/legal agreement.

R4. Exfiltration indicators turned on globally

Description: The **indicators** the departing-user policy needs, enabled under **Settings** → **Policy indicators**: **Office indicators** (SharePoint/OneDrive download, file shared externally, email sent to external/personal recipient) and **Device indicators** (file copied to USB/removable media, file copied to personal cloud, file printed, file downloaded from cloud to device). **Cumulative exfiltration detection** / sequence detection as a risk booster where agreed. **Why:** The policy can only detect activities whose

indicators are enabled; indicators are a **global** switch the policy then draws from. **Verify: Settings** → **Policy indicators** — confirm the Office and Device families are checked. Device indicators additionally require the endpoint prerequisites in R5. `IRMDEPART-Test-HRConnector.ps1` reminds you which families to confirm. **Implement if missing:** Enable the Office and Device indicator families (see `03-implementation.md` for the exact set).

R5. Endpoint (device) prerequisites for device indicators

Description: For **device/endpoint indicators**, devices **onboarded** to Microsoft Purview (endpoint DLP onboarding, which uses the same onboarding as Microsoft Defender for Endpoint) and running a supported OS. **Why:** Device indicators (USB copy, print, copy-to-personal-cloud) — the highest-signal exit-theft activities — only fire from **onboarded** devices; un-onboarded endpoints are invisible to the policy. **Verify:** Purview portal → **Settings** → **Device onboarding** shows onboarded devices; a test device appears in endpoint DLP activity. `IRMDEPART-Test-HRConnector.ps1` reports whether the device path is ready and points you to the onboarding check. **Implement if missing:** Onboard the in-scope devices before relying on device indicators. Until then, device-based detections will not fire (Office/email indicators still will).

R6. The Microsoft 365 HR connector (the departing-user trigger)

Description: The **Microsoft 365 HR connector** importing **resignation/termination dates** (and, optionally, job-level changes) from your HR system — the **triggering event** for *Data theft by departing users*. **Why:** The departing-user template scopes a user for detection based on their **leaver date**; without the HR connector (or the Entra account-deletion fallback) there is **no trigger** and the policy scores no one. This is the requirement most likely to be missing. **Verify:** Purview portal → **Settings** → **Data connectors** (or **Data connectors** in the M365 admin center) — the HR connector shows **recent successful uploads**. `IRMDEPART-Test-HRConnector.ps1` reports connector presence/freshness where readable and confirms audit ingestion. **Implement if missing:** Create the HR connector (Entra app registration + the CSV/API upload Microsoft documents) and schedule regular uploads. **Alternative trigger:** Entra **account deletion** can trigger the departing-user policy without an HR feed — coarser (it fires as the account is removed, i.e. usually *after* the last day) but requires no connector. Prefer the HR feed so you catch theft **before** the account is gone.

R7. A named pilot scope group

Description: A named security group — `SG-Departing-Pilot` — holding the small set of users the policy is scoped to for the pilot, before any broader rollout. **Why:** IRM thresholds and exclusions need **tuning against real activity**; a small pilot scope prevents alert floods, false positives, and over-collection — and keeps the privacy footprint minimal while you validate. **Verify:** Entra → **Groups** shows `SG-Departing-Pilot` with the agreed pilot members. `IRMDEPART-Set-Scope.ps1 -WhatIf` previews membership changes. **Implement if missing:** Create the group and populate it with the agreed pilot users (with HR/legal). For production, this becomes the standing **monitored-leaver** population — expand deliberately (R10 / Implementation Phase 7).

R8. (Optional) Priority user group for high-risk leavers

Description: Where exit risk concentrates in specific populations (executives, R&D, privileged admins), an optional **priority user group** — `PUG-HighRisk-Leavers` — so higher-sensitivity scoring can target

them. **Why:** Priority-user scoring boosts detection for the roles whose departure is most damaging; it also helps you scope narrowly (privacy). **Verify: Settings** → **Priority user groups** — confirm the group and membership are correct. **Implement if missing:** Define the priority group **with HR/legal** (membership in a "priority" group is itself sensitive). It is **optional**; the core policy does not depend on it.

R9. HR, legal, privacy (and works-council / employee-relations) engagement and lawful basis

Description: Named, engaged stakeholders from **HR, legal, privacy**, and — where applicable — **works councils / employee representatives**, plus a documented **lawful basis / notice / consultation** for monitoring departing-employee activity in your jurisdiction(s), and the **agreed anonymization / de-anonymization rules**. **Why:** The policy monitors people. In many regions this **requires** notice, consultation, or a specific lawful basis **before** you switch it on; the **applicability is a legal determination**, and case outcomes are **HR/legal's**, not the administrator's. **Verify:** Confirm the named stakeholders, the recorded lawful basis / notice, and the agreed anonymization rules **in writing** before enabling the policy. **Implement if missing: Stop** and obtain them. This is a hard gate — do not enable the departing-user policy without it. (See `global-requirements-purview.md` §5.)

R10. Change control for scope expansion

Description: A **change-control** process for growing the policy scope from `SG-Departing-Pilot` to the standing monitored-leaver population, after the pilot gates pass. **Why:** Expanding who is monitored is privacy-sensitive and high-impact; it must be deliberate, reversible, and agreed — not a one-click tenant-wide switch. **Verify:** Confirm a change window/approval path and that expansion goes through it. `IRMDEPART-Set-Scope.ps1` (`-WhatIf`) previews each expansion. **Implement if missing:** Agree change control before expanding scope beyond the pilot.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

Implementation — Departing-Employee Data-Theft Monitoring Quickstart

This is the ordered, do-this-then-that guide. It follows the standard model (**Assess** → **Design** → **Configure** → **Pilot (limited scope)** → **Validate** → **Expand**) and — because this capability is HR/privacy-sensitive — it **configures the privacy guardrails and role separation FIRST**, before the policy exists. Every object is named verbatim so the scripts, testing, and troubleshooting line up. Replace the `contoso.com` / sample group names with your own.

> ***Portal note.*** *Insider-risk policy authoring is done in the **Microsoft Purview portal** (`purview.microsoft.com` → **Insider Risk Management**). PowerShell (Security & Compliance PowerShell / Graph) is used here for **readiness, role/scope verification, and reporting** — not to*

*invent a policy-authoring path IRM does not expose. Where a portal path or capability may differ by tenant/licence, **verify against your licensing/tenant**.*

***Hard gate before you start.** Do **not** begin Phase 2 until Requirement **R9** (HR/legal/privacy engagement + lawful basis + agreed anonymization rules) is satisfied **in writing**. This policy monitors people; the applicability is a legal determination, not a technical one.*

Named objects (verbatim — used across docs, scripts, tests)

Object	Name	Notes
Pilot scope group	`SG-Departing-Pilot`	Small pilot population; becomes the standing monitored-leaver group at Expand.
Priority user group (optional)	`PUG-HighRisk-Leavers`	Executives / R&D / privileged admins, if used (R8).
Policy	`IRM-DepartingUser-DataTheft`	From MS template **Data theft by departing users**.
Role groups	Insider Risk Management **Admins / Analysts / Investigators / Auditors**	Avoid the combined **Insider Risk Management** group for operators.

Phase 0 — Assess (confirm you can build safely)

1. **Confirm licensing (R1).** Verify E5 / E5 Compliance / IRM add-on is assigned to in-scope users. IRM appears in the Purview left navigation.

1. **Confirm role separation (R2).** Run `IRMDEPART-Discovery.ps1` (read-only). Confirm the four functional role groups exist with minimal, correct membership, and that **no person holds a conflicting combination** (Admin + Investigator, etc.). The combined **Insider Risk Management** role group should **not** be assigned to production operators.

• **Gate 0a:** role separation clean → continue. Overlap → fix membership **before** proceeding.

1. **Confirm privacy posture (R3).** In **Insider Risk Management** → **Settings** → **Privacy**, confirm **"Show anonymized versions of usernames"** is selected. `IRMDEPART-Discovery.ps1` flags this to confirm in-portal.

• **Gate 0b:** anonymization **on** (or an explicit, written privacy/legal exception) → continue.

1. **Confirm the toolchain** (`global-requirements-purview.md` §3): `Connect-IPPSSession`, `Connect-ExchangeOnline`, and `Connect-MgGraph` all succeed with an MFA-capable admin.

1. **Confirm audit ingestion + readiness.** Run `IRMDEPART-Test-HRConnector.ps1` (read-only): unified audit-log ingestion on, HR-connector presence/freshness where readable, and the indicator/device portal checks.

Phase 1 — Design (agree it with HR/legal, then name everything)

Decide and **record with HR/legal/privacy**:

• **Anonymization:** ON (default). Document **who** may de-anonymize, **on what basis**, with **what approval**, and that every de-anonymization is** audited**.

• **Scope:** the **minimum** population. Pilot with `SG-Departing-Pilot`; production is the standing set of actual/imminent leavers, expanded deliberately.

• **The policy** and its verbatim name: `IRM-DepartingUser-DataTheft` — template **Data theft by departing users**.

• **Trigger:** HR-connector resignation/termination date (preferred) — or Entra account deletion (fallback).

• **Indicators:** Office exfiltration (download / external share / email to external-personal) + Device exfiltration (USB / personal cloud / print) — device indicators need onboarding (R5).

• **Priority users (optional):** `PUG-HighRisk-Leavers` — with HR/legal.

Phase 2 — Configure the guardrails FIRST

2.1 Role separation (do this before the policy exists)

In **Settings** → **Roles & scopes** → **Permissions** (or Purview **Roles & scopes**), assign named people to **one** function each:

Function	Role group	Sees identity?	Purpose
Build policy/settings	**Insider Risk Management Admins**	No	Configure the policy/indicators/connector
Triage	**Insider Risk Management Analysts**	Anonymized by default	Work the alert/case queue
Deep investigate	**Insider Risk Management Investigators**	De-anonymized where justified	Case + content/forensic detail
Audit the reviewers	**Insider Risk Management Auditors**	n/a (audit log only)	Independent oversight

• **Do not** assign the combined **Insider Risk Management** role group to operators.

• **Pass/fail:** re-run `IRMDEPART-Discovery.ps1` — separation clean, no conflicting combinations.

• **Rollback:** remove any mis-assigned membership; role groups are additive and safe to correct.

2.2 Privacy and global settings

In **Insider Risk Management** → **Settings**:

• **Privacy** → **Show anonymized versions of usernames** (ON).

• **Policy indicators** → enable the Office and Device families the policy needs (2.3).

• **Policy timeframes** → set the **activation window** (detection window after the trigger, e.g. 30 days) and **past activity** (look-back, e.g. 90 days) per your HR/legal agreement — for a leaver, the look-back is what lets you see exfiltration that began *before* the resignation was recorded.

• **Intelligent detections** → keep the default alert-volume and file-type exclusions initially.

• **Priority user groups** → create `PUG-HighRisk-Leavers` only if used (with HR/legal).

2.3 Turn on indicators (global switch the policy draws from)

Under **Settings** → **Policy indicators**, enable at least:

• **Office indicators:** SharePoint/OneDrive download, file shared externally, email sent to external/personal recipient.

• **Device indicators:** file copied to USB/removable media, file copied to personal cloud, file printed, file downloaded from cloud to device. *(Requires device onboarding — R5.)*

• **Cumulative exfiltration detection / sequence detection** (risk boosters) as agreed — useful for a leaver quietly taking many files over days.

Phase 3 — Wire the trigger (HR connector)

1. **Settings** → **Data connectors** (or M365 admin center → **Data connectors**) → create the **HR connector**.

1. Register the **Entra app** the connector requires, note the **connector job ID**, and configure the **CSV/API upload** Microsoft documents (resignation date, termination date, and optionally job-level change). **No secrets in scripts** — the upload credential lives in the connector app, not in code.

1. Schedule regular uploads and confirm the connector shows **recent successful ingestion**.

2. **Alternative trigger:** if you have no HR feed, the departing-user policy can trigger on **Entra account deletion** — coarser (fires as the account is removed), but no connector required.

• **Pass/fail:** `IRMDEPART-Test-HRConnector.ps1` reports connector presence/freshness and audit ingestion; the portal shows a recent successful upload.

Phase 4 — Build the one policy (scoped to the pilot)

Insider Risk Management → **Policies** → **Create policy**, choose the template, and scope to `SG-Departing-Pilot` only:

1. `IRM-DepartingUser-DataTheft` — template **Data theft by departing users**.

• **Trigger:** HR-connector leaver date (or Entra account deletion).

• **Indicators:** Office + Device exfiltration indicators (2.3).

• **Scope:** `SG-Departing-Pilot` (add `PUG-HighRisk-Leavers` scoring only if used).

• **Pilot rule:** keep scope at `SG-Departing-Pilot`; leave default thresholds initially. **Do not** widen scope yet.

• **Pass/fail:** the policy shows **Status = On** and **healthy** (no configuration warning) in the policy list. `IRMDEPART-Set-Policy.ps1 -WhatIf` validates prerequisites and prints the intended configuration/plan before you build in the portal.

• **Rollback:** set **Status = Off**; the policy is inert while off and scores no one.

Phase 5 — Validate (run the gates)

Work the gates in `05-testing.md`:

• Role separation clean (no conflicting combinations).

• Anonymization **on** in the reviewer experience.

• Office + Device indicators enabled; devices onboarded; HR connector fresh (or account-deletion trigger chosen deliberately).

• The policy **On + healthy**, scoped to `SG-Departing-Pilot`.

• A **sanctioned test**: a pilot test account, marked as a leaver in the HR feed, performs a **benign** exfiltration action (e.g. copying a harmless test file to removable media on an **onboarded** device, or emailing a test file to an external test address) within the detection window → produces **scored activity** → **an alert**.

• The alert can be **triaged** and **escalated into a case**, and the case shows the **audited** reviewer trail.

• **Do not proceed to Expand until every gate passes** and HR/legal confirm the alert→case→hand-off workflow is acceptable.

Phase 6 — Operate the review flow (and hand off to HR/legal)

1. **Triage** (Analyst): review the alert queue; for each alert **confirm** (real risk) or **dismiss** (benign), with a note. Reviewers see the **anonymized** experience by default.

1. **Escalate to a case** (Analyst/Investigator): confirmed, meaningful alerts become **cases** — the container with the user's scored activity, notes, and case actions.

1. **Investigate** (Investigator): where justified and role-permitted, view content/forensic detail and **de-anonymize identity** — this action is **audited** (Auditors can see it).

1. **Case actions:** send a **notification**, **escalate to eDiscovery** or **Communication Compliance**, or **resolve**. **Determination and any disciplinary outcome are HR/legal's** — the policy routes evidence to them; it does not decide.

1. **Audit** (Auditor): periodically review the **IRM audit log** to confirm reviewers acted within

policy (especially de-anonymizations). `IRMDEPART-Report.ps1` gives a privacy-respecting rollup.

Phase 7 — Expand (only after the gate passes)

Widen scope **deliberately** — from `SG-Departing-Pilot` to the standing monitored-leaver population — using `IRMDEPART-Set-Scope.ps1` (`-WhatIf` first). In production, keep the scope group **in step with your leaver process**: ideally the HR connector / a joiner-mover-leaver automation adds imminent leavers to the group. Re-run the gates after each expansion. Keep anonymization on and role separation intact.

Rollback summary

Change	Rollback
Role assignment error	Remove the mis-assigned member from the role group (additive, safe).
Policy too noisy in pilot	Set policy **Status = Off**, tune thresholds/exclusions, re-pilot.
Anonymization mis-set	Re-select **Show anonymized versions of usernames** (Settings → Privacy).
Scope expanded too far	Remove the added members from `SG-Departing-Pilot` (`IRMDEPART-Set-Scope.ps1`).
HR connector bad data	Pause uploads, correct the source export, re-upload; trigger re-evaluates.

> ***Never** delete cases or audit records to "clean up" — they are the defensible, HR/legal-facing evidence trail. Retention/disposition of IRM records is a **records/legal determination**.*

Testing & Validation — Departing-Employee Data-Theft Monitoring Quickstart

Run these gates in order. Each has an explicit **pass/fail** signal. **Do not expand scope** (Phase 7) until every gate passes **and** HR/legal have confirmed the alert→case→hand-off workflow is acceptable. Where a test involves a real user's activity, use a **sanctioned test account/action** with HR/legal awareness — do not covertly test on a real employee.

Use the scripts where noted; they are read-only or `-WhatIf` and change nothing you don't approve.

Gate 1 — Role separation is clean (privacy control)

Why: The person who defines risk must not be the person who unmasks identity; both must be independently audited. **How:** Run `IRMDEPART-Discovery.ps1`. Review the role-group membership table. **Pass:** The four functional groups (**Admins / Analysts / Investigators / Auditors**) have minimal, correct membership; **no single person holds a conflicting combination** (e.g. Admin **and** Investigator); the combined **Insider Risk Management** role group is **not** assigned to operators. **Fail:** Any conflicting

combination, or over-broad membership → fix in **Roles & scopes** before continuing.

Gate 2 — Anonymization is ON

Why: Reviewers must see pseudonymized identities by default. **How:** Purview → **Insider Risk Management** → **Settings** → **Privacy**; `IRMDEPART-Discovery.ps1` flags the posture to confirm in-portal. **Pass: "Show anonymized versions of usernames"** is selected; the reviewer experience shows coded identifiers, not names. **Fail:** Anonymization off without a **written** privacy/legal exception → re-enable it.

Gate 3 — Trigger and indicators are ready

Why: The departing-user policy can only score a user once the **trigger** fires, and can only detect activities whose **indicators** are enabled. **How:** Run `IRMDEPART-Test-HRConnector.ps1`; cross-check in **Settings** → **Policy indicators / Data connectors / Device onboarding**. **Pass:** Unified audit-log ingestion **on**; the **HR connector** shows a recent successful upload (or you are deliberately using the Entra-account-deletion trigger); the required **Office and Device indicator families are enabled**; **device onboarding** shows onboarded devices (for device indicators). **Fail:** Audit ingestion off, HR connector stale, a needed indicator off, or no devices onboarded → fix the specific prerequisite (see `02-requirements.md` R4–R6 and `03-implementation.md` Phase 3).

Gate 4 — The policy is On and healthy, scoped to the pilot

Why: A misconfigured or over-scoped policy produces noise or over-collection. **How:** Purview → **Insider Risk Management** → **Policies**; `IRMDEPART-Set-Policy.ps1 -WhatIf` to re-validate prerequisites/plan. **Pass:** `IRM-DepartingUser-DataTheft` shows **Status = On** and **healthy** (no configuration warning), scoped to `SG-Departing-Pilot` only. **Fail:** The policy shows a health/configuration warning, or is scoped beyond the pilot → correct before testing detections.

Gate 5 — The trigger actually scopes a leaver

Why: The whole capability hinges on the leaver signal reaching the policy; prove it before relying on detections. **How:** Ensure a **pilot test account** (in `SG-Departing-Pilot`) has a **resignation/termination date** in the HR-connector upload (or is deleted, if using the account-deletion trigger). Confirm in the portal that the user is brought **in scope for detection** within the activation window. **Pass:** The test leaver is scoped for detection after the trigger (leaver date / account deletion). **Fail:** The user is never scored/in-scope → check the HR upload succeeded and the leaver date is recent/valid (`IRMDEPART-Test-HRConnector.ps1`), or that the account-deletion trigger is selected.

Gate 6 — A sanctioned test exfiltration produces a scored alert

Why: Proves the end-to-end detection path (trigger → indicator → score → alert) actually works. **How:** With the Gate-5 **pilot test leaver** on an **onboarded** device, perform a **benign, sanctioned** exfiltration action within the detection window — e.g. copy a harmless test file to removable media, or email a test file to an external test address. **Pass:** The activity appears as **scored activity** and raises an **alert** in the queue with a severity, within the policy's activation window. **Fail:** No alert after the detection window → confirm the trigger fired (Gate 5), the indicator is enabled, and the device is onboarded (Gate 3).

Gate 7 — Alert triages and escalates into an audited case

Why: The operational review flow and the audit trail are the point. **How:** As an **Analyst**, triage the Gate-6 alert (confirm), then escalate to a **case**. As an **Auditor**, check the IRM audit log. **Pass:** The alert can be **confirmed/dismissed** with a note; a confirmed alert becomes a **case**; any **de-anonymization** in the case is recorded in the **IRM audit log** (visible to Auditors). **Fail:** Cannot triage/escalate (likely a role issue — Gate 1), or reviewer actions are not audited → re-check role assignments and settings.

Gate 8 — HR/legal hand-off confirmed

Why: Determinations are theirs, not the administrator's. **How:** Walk the case workflow with HR/legal; confirm they accept how evidence is routed (notification / eDiscovery / Communication Compliance / resolve) and who decides outcomes. **Pass:** HR/legal confirm the hand-off is acceptable and the **determination/outcome sits with them**. **Fail:** Ambiguity about who decides outcomes → resolve **before** expanding scope.

Gate 9 — Reporting rollup is coherent

Why: Leadership needs a defensible, privacy-respecting summary. **How:** Run `IRMDEPART-Report.ps1` (read-only) and compare the rollup to the portal Alerts/Cases dashboards. **Pass:** The rollup (counts by operation/time over the window) reconciles with the portal, with no identity exposure beyond what the report is authorized to show. **Fail:** Rollup diverges materially from the portal → the portal dashboards are authoritative; reconcile before reporting.

Exit criteria (all must be true before Expand)

- Role separation clean; no conflicting combinations (Gate 1)
- Anonymization ON (Gate 2)
- Trigger + indicators ready; audit ingestion on (Gate 3)
- Policy On + healthy, pilot-scoped (Gate 4)
- Trigger scopes a test leaver (Gate 5)
- Sanctioned test → scored alert (Gate 6)
- Alert → audited case (Gate 7)
- HR/legal hand-off confirmed (Gate 8)
- Reporting reconciles with portal (Gate 9)

Troubleshooting — Departing-Employee Data-Theft Monitoring Quickstart

Symptom → likely cause → fix, for the failure modes you actually hit deploying and operating the departing-user policy. Work top-down; most "it isn't working" reports are a missing **trigger** (the HR connector), a disabled **indicator**, or a **licensing/role** gap — not a broken product. When a capability seems absent, **verify it against your licensing/tenant** before assuming a bug (IRM is plan-gated and the

portal evolves).

Insider Risk Management doesn't appear in the portal / Settings won't open

- **Cause:** Missing licence (E5 / E5 Compliance / IRM add-on) or missing IRM role.
- **Fix:** Confirm the licence in the M365 admin center (R1) and that your account is in an **Insider Risk

Management** role group (Admins to configure). `IRMDEPART-Discovery.ps1` lists role-group membership. Verify capability availability against your licensing/tenant.

The policy is On but produces NO alerts

Work these in order — this is the most common report, and for a departing-user policy the usual answer is **the trigger never fired**:

1. **No leaver trigger.** The user is only scored after the **triggering event**. The HR connector has

no recent leaver record for the user (or is stale), and you're not using the Entra account-deletion trigger. Check **Settings** → **Data connectors** for a recent successful upload; run `IRMDEPART-Test-HRConnector.ps1`. Confirm the user's resignation/termination date is present and valid.

1. **Indicator disabled.** The activity's **indicator** is off under **Settings** → **Policy indicators**.

Enable the needed Office/Device family.

1. **Device not onboarded.** Device indicators (USB/print/personal-cloud) only fire from **onboarded**

devices (R5). Check **Settings** → **Device onboarding** — a leaver on an un-onboarded laptop is invisible.

1. **Detection window.** The activity fell outside the policy's **activation window / past-activity**

timeframe (Settings → Policy timeframes). For leavers, widen **past activity** so exfiltration that began before the resignation was recorded is still caught.

1. **User not in scope / unlicensed.** The user isn't in `SG-Departing-Pilot` or isn't licensed. Add them

to scope (`IRMDEPART-Set-Scope.ps1`) and confirm licensing.

HR connector shows no / stale data — departing-user detection silently stopped

- **Cause:** Upload job failing, schedule lapsed, or the source export changed shape.
- **Fix:** In **Settings** → **Data connectors** open the HR connector and check the last upload status/time

(`IRMDEPART-Test-HRConnector.ps1` flags staleness). Re-run the upload; validate the CSV/API schema (resignation/termination dates) matches what Microsoft's connector expects. The upload credential lives in the **connector app**, not in any script. If you have no HR feed at all, switch the policy to the **Entra account-deletion** trigger (coarser — it fires as the account is removed, so you lose the before-last-day window — but works without a connector).

Device indicators never fire even though the leaver copied files

• **Cause:** Device not onboarded to Purview endpoint (same onboarding as Defender for Endpoint), the device indicator family is off, or an unsupported OS.

• **Fix:** Confirm onboarding (**Settings** → **Device onboarding**), enable **Device indicators** (**Settings → Policy indicators**), and verify the OS is supported. `IRMDEPART-Test-HRConnector.ps1` points you to these checks.

Reviewers see real names when they shouldn't (or "why is everyone anonymized?")

• **Cause:** Anonymization posture mis-set, or a role confusion about who may de-anonymize.

• **Fix: Settings** → **Privacy** must have **"Show anonymized versions of usernames"** selected (ON) — the default and expected posture. Analysts see the **anonymized** experience; **de-anonymization** is an **Investigator**-level, justified, **audited** action (Auditors can see it in the IRM audit log). If anonymization was turned off, re-enable it unless privacy/legal agreed an exception in writing (Gate 2).

An account can both build the policy and unmask identities (separation broken)

• **Cause:** Someone holds a **conflicting** combination (e.g. **Admins + Investigators**), or the combined **Insider Risk Management** role group was assigned to an operator.

• **Fix:** Run `IRMDEPART-Discovery.ps1` — it flags conflicting combinations. In **Settings → Roles & scopes**, **reduce each person to** one **function; remove operators from the combined** Insider Risk Management** group. Treat this as a governance finding, not a convenience (Gate 1).

"Access denied" triaging alerts or opening a case

• **Cause:** Wrong role. Triage needs **Analysts**; deep case + content needs **Investigators**. Admins **cannot** see alert/case user activity by design.

• **Fix:** Assign the correct functional role group to the operator — without breaking separation (don't stack Admin + Investigator on one person).

Alerts are overwhelming / lots of false positives in the pilot

• **Cause:** Thresholds too sensitive, no exclusions, or scope too broad for a first pilot.

• **Fix:** This is why you **pilot with a small scope first**. Tune **intelligent detection** settings, add file-type/domain **exclusions** (recording why), and keep scope at `SG-Departing-Pilot` until noise is acceptable. Set a noisy policy **Off**, tune, and re-pilot — don't expand scope to "average out" the noise.

A user resigned but was never scored

- **Cause:** The leaver record didn't reach the policy, or the user isn't in scope.
- **Fix:** Confirm the HR upload succeeded and the leaver date is recent/valid

(`IRMDEPART-Test-HRConnector.ps1`), that the user is a member of `SG-Departing-Pilot` (`IRMDEPART-Set-Scope.ps1 -WhatIf`), and that the activation window covers the period since the trigger (Testing Gate 5).

`Get-InsiderRiskPolicy` / IRM cmdlets aren't recognized

- **Cause:** IRM authoring is **primarily portal-based**; the cmdlet surface is limited and

tenant/version-dependent.

- **Fix:** Manage the policy in **purview.microsoft.com** → **Insider Risk Management** → **Policies**. The

scripts here deliberately use PowerShell for **readiness, role/scope verification, and reporting** — not to invent an authoring path. `IRMDEPART-Set-Policy.ps1 -WhatIf` prints the exact plan to apply in the portal.

`IRMDEPART-Report.ps1` returns no records

- **Cause:** Unified audit-log ingestion off, window too short, or no IRM activity yet.
- **Fix:** Enable audit ingestion (`IRMDEPART-Test-HRConnector.ps1`), widen `-DaysBack`, and remember the

portal Alerts/Cases dashboards are authoritative — the CSV is a summary aid, not the source of truth (Gate 9).

Connect-IPPSSession / Connect-MgGraph fails

- **Cause:** Module not installed, modern-auth/MFA blocked, or wrong account.
- **Fix:** Install **ExchangeOnlineManagement** and **Microsoft.Graph**, sign in with an **MFA-capable**

admin, and ensure Security & Compliance PowerShell is reachable. See `global-requirements-purview.md` §3.

When to stop and escalate to HR/legal (not troubleshoot)

- You have a **real** confirmed case of departing-employee theft and need a determination or disciplinary

decision → that is **HR/legal's**, not an administrator's, and not a "fix" in this guide.

- You're unsure whether you may **enable monitoring** or **de-anonymize** a user → stop and get the

lawful-basis / privacy decision first (R9). The technical method is here; the determination is not.

Best Practices — Departing-Employee Data-Theft Monitoring Quickstart

Operating principles that keep a departing-user monitoring capability **effective, defensible, and privacy-respecting**. They reflect the three non-negotiables: privacy by design, strict role separation, and determinations that belong to HR/legal.

Privacy first — always

- **Keep anonymization ON.** Reviewers see pseudonymized identities by default. De-anonymization is a

justified, role-gated, audited exception — never a routine step, never the administrator's call.

- **Scope to the minimum.** Put only actual/imminent **leavers** in scope, not the whole workforce. A

narrow, purpose-built scope is both quieter and far easier to justify to privacy/legal — and it is the whole reason this template uses a trigger.

- **Least data, least reveal.** Reveal identity only when a case genuinely requires it, and record why.
- **Document the privacy decisions** (anonymization posture, who may de-anonymize, on what basis) and

keep them current with privacy/legal.

Role separation — enforce it, then watch it

- **One function per person.** Admins configure; Analysts triage; Investigators go deep; Auditors watch

the reviewers. Do **not** concentrate roles, and do **not** assign the combined **Insider Risk Management** role group to operators.

- **Independent audit.** Assign **Auditors** who are **not** Admins/Analysts/Investigators, and have them

review the IRM audit log on a schedule — especially every **de-anonymization**.

- **Re-verify after every change.** Re-run `IRMDEPART-Discovery.ps1` after any role change; treat a

conflicting combination as an incident, not a convenience.

Determinations stay with HR/legal

- **The policy produces evidence, not verdicts.** An alert or a case is a signal and an audited trail.

Whether it reflects misconduct, and what happens next, is an **HR/legal/privacy determination**.

- **Route, don't rule.** Use case actions to route evidence (notification, eDiscovery, Communication

Compliance, resolve). The employment decision is made by the people authorized to make it.

- **Engage before you enable.** Confirm the lawful basis / notice / consultation for your

jurisdiction(s) **before** switching the policy on. Applicability is a legal determination.

Make the leaver trigger reliable — this is where the value lives

- **Prefer the HR trigger over account-deletion.** The HR-connector leaver date lets you detect theft

before the account is gone; account-deletion fires *after* the last day, when the damage is usually done. Use account-deletion only as a fallback when there is no HR feed.

• **Keep the HR connector fresh.** A stale leaver feed means departing-user detection silently stops.

Monitor connector health (`IRMDEPART-Test-HRConnector.ps1`) and alert on failed uploads.

• **Tie the scope group to the leaver process.** In production, have your joiner-mover-leaver automation

add imminent leavers to `SG-Departing-Pilot` (renamed for prod) so the monitored population tracks reality without manual effort.

• **Mind the look-back window.** Set **past-activity** long enough to catch exfiltration that began

before the resignation was recorded — a resigning employee often starts copying files weeks ahead.

Detection hygiene

• **Enable only the indicators you need**, and make sure their prerequisites are met — **device

onboarding** for the high-signal USB/print/personal-cloud indicators; Office indicators for email/share exfiltration.

• **Use cumulative/sequence detection** for the classic slow leak — many small copies over days that no

single event would flag.

• **Onboard the devices that matter.** Un-onboarded endpoints are invisible to device indicators; a

leaver on an un-onboarded laptop is a blind spot.

Pilot and tune before you rely

• **Pilot scope, then expand.** Start at `SG-Departing-Pilot`, tune thresholds and exclusions against

real activity, and expand **group-by-group** only after the gates pass.

• **Tune out noise deliberately.** Use file-type/domain exclusions and the intelligent-detection settings

to cut false positives — but record why, so exclusions don't quietly blind the program.

Operations and evidence integrity

• **Triage promptly and consistently.** A backlog of un-triaged leaver alerts undermines both

effectiveness and fairness — and leaver windows are short. Agree triage SLAs with the team.

• **Never delete cases/audit records to tidy up.** They are the defensible, HR/legal-facing trail.

Retention/disposition of IRM records is a **records/legal determination**.

• **Report without over-exposing.** Leadership rollups should show counts/severity/trends

(`IRMDEPART-Report.ps1`) — not identities — unless the audience is authorized.

Change control and safety

• **All policy/scope changes go through change control**, previewed with `-WhatIf` where a script supports it.

• **No secrets in automation.** Scripts authenticate interactively (`Connect-IPPSSession` / `Connect-MgGraph`); the HR-connector credential lives in the connector app, never in code.

• **Verify against your licensing/tenant.** IRM capabilities are plan-gated and the portal evolves — confirm availability rather than assuming, and re-check when Microsoft ships changes.

Fit with the rest of Purview

• **Departing-user + DLP.** DLP policies on your sensitive content complement the leaver policy — DLP blocks/warns in the moment; the leaver policy scores the pattern of exfiltration.

• **Departing-user + eDiscovery / Communication Compliance.** Case actions can escalate into these workflows — keep role separation consistent across all of them.

• **Departing-user + audit.** The unified audit log records IRM admin/reviewer activity; keep audit logging on and use it as independent corroboration. This quickstart can later grow into a full insider- risk program (data leaks, security-policy violations) on the same guardrails.

Deliverables Summary — Departing-Employee Data-Theft Monitoring Quickstart

Everything included in this solution, and what each piece is for.

Documentation

Document	Purpose
Solution Overview (`01-solution-overview.md`)	What the quickstart delivers, the HR/privacy sensitivity, the departing-user model (template, trigger, indicators, HR connector, alerts→cases), and the guardrails.
Requirements (`02-requirements.md`)	Solution-specific prerequisites — licensing, the role groups + strict separation, anonymization posture, exfiltration indicators, endpoint onboarding, the HR-connector trigger, pilot scope, HR/legal engagement + lawful basis, change control.
Implementation (`03-implementation.md`)	Ordered steps: guardrails and role separation **first**, then indicators, the HR-connector trigger, the one policy from template, pilot, validate, expand — with pass/fail gates and rollback.
Testing & Validation (`05-testing.md`)	Nine pass/fail gates from role separation and anonymization through a sanctioned test leaver → scored alert → audited case and the HR/legal hand-off.

Document	Purpose
Troubleshooting (`06-troubleshooting.md`)	The common failure modes (no alerts, stale HR connector, device indicators not firing, role/permission issues, anonymization confusion) and how to resolve them.
Best Practices (`07-best-practices.md`)	Privacy-first, role-separation, determinations-with-HR/legal, reliable-trigger, detection-hygiene, pilot-and-tune, and evidence-integrity guidance.
Executive Summary (`executive-summary.md`)	One-page business framing for decision-makers.

PowerShell tools (5)

All tools are **read-only or `-WhatIf` by default**, authenticate **interactively** (no credentials in code), and use **Security & Compliance PowerShell** (`Connect-IPPSSession`), **Exchange Online** (`Connect-ExchangeOnline`, for role groups), and/or **Microsoft Graph** (`Connect-MgGraph`). Insider-risk policy *authoring* is a portal action; these tools handle readiness, verification, planning, scoping, and reporting.

Script	Type	What it does
`IRMDEPART-Discovery.ps1`	Read-only	Readiness + **role-separation** + **privacy-settings** assessment: inventories the IRM role groups and their membership, flags any conflicting combinations, reports policy presence where readable, and prompts to confirm the anonymization posture in-portal.
`IRMDEPART-Test-HRConnector.ps1`	Read-only	**Trigger / indicator readiness** checker: confirms unified audit-log ingestion, reports HR-connector presence/freshness where readable (the departing-user trigger), and lists the portal checks for indicators and device onboarding.

Script	Type	What it does
`IRMDEPART-Set-Policy.ps1`	`-WhatIf` default	**Policy-from-template plan** helper for *Data theft by departing users*: validates that the prerequisites (roles, indicators, trigger source, anonymization) are in place and prints the exact intended policy configuration/plan to apply in the portal; a `-Commit` path only acts where a supported cmdlet exists.
`IRMDEPART-Report.ps1`	Read-only	**Alert / case rollup** report: summarizes IRM activity readable from the unified audit log (by operation/time) to CSV for a leadership rollup; notes the portal Alerts/Cases dashboards as authoritative; does not de-anonymize.
`IRMDEPART-Set-Scope.ps1`	`-WhatIf` default	**Scope helper**: previews and (with `-WhatIf:$false`) applies membership changes to the pilot/monitored-leaver group so expansion stays deliberate and reversible.

Named objects (verbatim — used across docs, scripts, and tests)

- **Pilot scope group:** `SG-Departing-Pilot` (becomes the standing monitored-leaver group at Expand)
- **Priority user group (optional):** `PUG-HighRisk-Leavers`
- **Policy:** `IRM-DepartingUser-DataTheft` — *Data theft by departing users*
- **Role groups (separation):** Insider Risk Management **Admins / Analysts / Investigators / Auditors** (avoid the combined **Insider Risk Management** group for operators)

What this solution deliberately does NOT do

- It does **not** make investigative or disciplinary **determinations** — those are HR/legal's.
- It does **not** disable anonymization or concentrate roles for convenience.
- It does **not** invent portal paths or cmdlets — where policy authoring is portal-only, the tools stop at readiness/validation and say so.
- It does **not** decide your **lawful basis** for monitoring — that is a legal determination for your

jurisdiction(s).

- It is a **focused quickstart** — it delivers the one departing-user policy, not a full insider-risk program (data leaks, security-policy violations, communication compliance). It is built on the same guardrails, so it can grow into one later.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

IRMDEPART-Discovery.ps1

Purpose: Connects to Exchange Online / Security & Compliance PowerShell and inventories the Insider Risk Management (IRM) role groups and their membership, then flags any account that holds a CONFLICTING COMBINATION of roles (e.g. Admins + Investigators) — the core privacy/separation check for a departing-employee monitoring capability. It also reports IRM policy presence where the tenant exposes it (looking for IRM-DepartingUser-DataTheft) and prompts you to confirm the anonymization (privacy) setting in the portal (that setting is portal-managed). Read-only — it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Discovery.ps1

How to run: powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Discovery.ps1

IRMDEPART-Report.ps1

Purpose: Produces a leadership rollup of Insider Risk Management activity that is readable from the unified audit log — counts of IRM-related administrative and review events over a time window, grouped by operation — and writes it to CSV. It is a SUMMARY aid: the authoritative alert and case detail lives in the Purview portal (Insider Risk Management -> Alerts / Cases). Read-only — it changes nothing and does not de-anonymize anyone. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Report.ps1 -DaysBack 30 -OutputCsv .\IRMDEPART-rollup.csv

How to run: powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Report.ps1 -DaysBack 30 -OutputCsv .\IRMDEPART-rollup.csv

IRMDEPART-Set-Policy.ps1

Purpose: A policy-from-template CONFIGURATION HELPER for the single policy this solution delivers: IRM-DepartingUser-DataTheft (Microsoft template "Data theft by departing users"). IRM policy authoring is done in the Microsoft Purview portal; this script does the safe, checkable part around it — it validates that the prerequisites are in place (the four IRM role groups exist, the trigger/indicators are ready, anonymization is expected ON) and prints the EXACT intended policy configuration/plan to apply in the portal. It DEFAULTS TO -WhatIf (plan only) and performs no writes. A -Commit switch is provided only for tenants where a supported IRM policy cmdlet is available; if none is present it explains that authoring is portal-based and stops. It never invents a cmdlet and never stores credentials. HOW TO RUN Plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Policy.ps1 Commit (only where a supported IRM policy cmdlet exists in your tenant): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Policy.ps1 -Commit

How to run: Plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Policy.ps1 Commit (only where a supported IRM policy cmdlet exists in your tenant): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Policy.ps1 -Commit

IRMDEPART-Set-Scope.ps1

Purpose: Manages membership of the departing-user scope group (SG-Departing-Pilot by default) so you can expand the "Data theft by departing users" policy from pilot to the standing monitored-leaver

population a batch at a time, and reversibly. Because the policy is scoped to this group, growing the group expands detection scope without editing the policy. It DEFAULTS TO -WhatIf (preview only) and changes nothing until you re-run with -WhatIf:$false. It only ADDS the members you pass and never retargets the policy directly, so expansion stays deliberate. Scoping people into IRM is privacy-sensitive — do it only within the HR/legal-agreed scope (i.e. actual/imminent leavers). HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

IRMDEPART-Test-HRConnector.ps1

Purpose: A readiness checker for the prerequisites that make the "Data theft by departing users" policy actually fire. It confirms unified audit-log ingestion is on (IRM signals depend on the audit pipeline), reports the HR data connector's presence/freshness where the tenant exposes it (the departing-user TRIGGER), and lists — as guided portal checks — device onboarding (for device indicators) and the Office/Device indicator families. Read-only — it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Test-HRConnector.ps1

How to run: powershell -ExecutionPolicy Bypass -File .\IRMDEPART-Test-HRConnector.ps1